AutoAudit — Documentação do Backend (Sprint 3)

03/11/2026 · Fatec Cotia · Processamento de Linguagem Natural · Prof. Braz Izaias da Silva Junior

Backend do AutoAudit, desenvolvido por Anderson Capelini Andrade (RA 2701352423046) e Moisés Germano Leite (RA 2701352423043) para a disciplina de Processamento de Linguagem Natural. Repositório: github.com/A-Capelini/AutoAudit.

Visão geral

O backend recebe uma política de segurança da informação (PDF ou DOCX), extrai o texto, aponta lacunas com regras de PLN, liga cada lacuna às normas NIST SP 800-53 e LGPD por busca semântica, calcula a nota de Saúde de Compliance (0 a 5) e grava tudo no MongoDB.

O frontend Streamlit consome a API. Se ela estiver fora do ar, o frontend cai em modo simulado e avisa o usuário com a mensagem "Resultado SIMULADO".

A Verificação Prática (pentest controlado em laboratório) **ainda não foi executada** nesta versão: `nota_pratica` e `verificacoes` voltam vazios, e a Saúde de Compliance considera apenas a avaliação documental.

Tecnologias e ambiente

O backend é escrito em Python 3.11, roda em ambiente Conda (conda-forge) no Ubuntu e usa MongoDB 7 em container Docker.

Camada	Tecnologia	Uso no projeto
Linguagem	Python 3.11	Todo o backend, o frontend e os scripts
API	FastAPI + Uvicorn (ASGI)	Rotas REST e documentação automática em `/docs`
Contrato de dados	Pydantic	Modelos `Relatorio`, `Lacuna`, `Verificacao`
Upload	python-multipart	Recebe o PDF ou DOCX enviado
Extração de texto	pypdf, python-docx	Leitura de PDF e de DOCX (inclui tabelas)
PLN	Expressões regulares (`re`) e regras explícitas	Detecção de lacunas, sem LLM
Busca semântica	sentence-transformers (`paraphrase-multilingual-mpnet-base-v2` , 768 dimensões, CPU) + FAISS (`faiss-cpu` , `IndexFlatIP`)	Normas próximas de cada lacuna
Banco de dados	MongoDB 7 (Docker Compose) + PyMongo 4.6 ou superior	Normas, auditorias e relatórios
Inspeção do banco	mongo-express (`localhost:8081`)	Visualização das coleções
Frontend	Streamlit 1.50 ou superior, requests	Interface e chamada à API
Configuração	python-dotenv, arquivo `.env` (não versionado)	`MONGO_URI` e credenciais
Ambiente	Conda (conda-forge), ambiente `autoaudit` , `setup/environment.yml`	Replicação em outras máquinas
Versionamento	Git e GitHub	Código, documentação e amostras

As versões de cada pacote ficam em `setup/environment.yml` . O LangChain e o `python-nmap` constam no ambiente para a próxima etapa (Verificação Prática); o código atual do backend não depende deles.

Os containers publicam as portas apenas em `127.0.0.1` : o MongoDB na 27017 e o mongo-express na 8081.

Arquitetura e estrutura do repositório

Uma auditoria percorre sete etapas, do upload até a resposta:

1. O frontend (`frontend/app.py` e `api_client.py`) envia o arquivo por `POST /auditorias` .
2. A API (`backend/main.py`) valida formato e tamanho e cria a auditoria no MongoDB com status `processando` .
3. `extracao.py` lê o texto e o divide em seções e sentenças.
4. `regras.py` detecta as lacunas e `analisador.py` calcula a nota.
5. `busca_normas.py` consulta o índice FAISS e `enriquecer_lacunas` liga cada lacuna às normas (`normas_ref`).
6. `db/repositorio.py` grava o relatório e marca a auditoria como `concluida` .
7. A API devolve o relatório no contrato e o frontend o exibe.

Pasta ou arquivo	Responsabilidade
`backend/main.py`	API FastAPI, modelos do contrato e ciclo de vida da auditoria

`backend/pln/extracao.py`	PDF e DOCX para texto, seções e sentenças
`backend/pln/regras.py`	Regras de detecção de lacunas
`backend/pln/analisador.py`	Nota documental, Saúde de Compliance e ligação com as normas
`backend/pln/busca_normas.py`	Busca semântica no índice FAISS
`backend/analisar_arquivo.py`	Analisa um documento no terminal, sem API nem banco
`backend/validar_gabarito.py`, `testar_api.py`, `testar_busca.py`	Validação do motor, da API e da busca
`db/repositorio.py`	Acesso ao MongoDB com regras de integridade
`db/init_db.py`, `seed_normas.py`, `seed_exemplo.py`, `build_faiss.py`	Criação do banco, carga das normas, exemplos e índice FAISS
`frontend/`	Interface Streamlit e cliente da API
`data/samples/`	Políticas fictícias de teste e o gabarito da Nimbus
`docs/`	Modelagem, dicionário de dados e roteiros

O backend soma cerca de 1,3 mil linhas de Python.

API REST

A API (FastAPI 0.3.0) expõe cinco rotas. A documentação interativa é gerada automaticamente em `http://localhost:8000/docs`.

Rota	O que faz
`GET /saude`	Informa se a API, o MongoDB e a busca semântica estão no ar
`POST /auditorias`	Recebe PDF ou DOCX (até 10 MB), analisa e grava auditoria e relatório
`GET /auditorias`	Histórico de execuções, mais recentes primeiro
`GET /relatorios`	Relatórios completos, usados pela tela Histórico
`GET /relatorios/{id}`	Um relatório completo, no formato do contrato

O ciclo de uma auditoria é `pendente`, `processando`, `concluida`. Em caso de falha, o status vai para `erro` e nenhum relatório é gravado.

Código	Situação
201	Auditoria concluída
400	Arquivo vazio
413	Arquivo maior que 10 MB
415	Formato não suportado (só `.pdf` e `.docx`)
422	Documento sem texto legível (por exemplo, PDF escaneado sem OCR)
500	Falha interna ao analisar
503	MongoDB indisponível

O contrato com o frontend, em JSON:

```
{
  "id": "...",
  "arquivo": "politica.pdf",
  "data": "03/11/2026 15:47",
  "nota_documental": 2.5,
  "nota_pratica": null,
  "saude_compliance": 2.5,
  "lacunas": [
    {
      "clausula": "Seção 4 — Controle de acesso e senhas",
      "trecho": "Os usuários devem utilizar senhas seguras...",
      "severidade": "alta",
      "referencia": "NIST SP 800-53 IA-5; ...",
      "problema": "...",
      "sugestao": "...",
      "mitre": "T1110 — Brute Force"
    }
  ],
  "verificacoes": null
}
```

A data usa o fuso `America/Sao_Paulo`. A severidade é `alta`, `média` ou `baixa`.

Pipeline de PLN

O motor usa regras explícitas, sem LLM: cada lacuna aponta a frase e o critério que a disparou, o resultado é reproduzível, o processamento é local e não há custo por chamada. Um LLM com recuperação no índice FAISS é a evolução natural.

1. Extração e segmentação

- PDF (pypdf) e DOCX (python-docx, incluindo tabelas e estilos de título). Ligaduras como "fi" são normalizadas.
- Em PDF, cabeçalhos, rodapés repetidos e números de página são removidos.
- As seções são reconhecidas por títulos numerados ("1. Objetivo", "4.2 Senhas"), numeração ABNT em sequência ("2 ESCOPO"), títulos em maiúsculas e capítulos ("CAPÍTULO II"). Linhas de sumário são ignoradas.
- Cada seção é dividida em sentenças, com tratamento de abreviações ("Art.", "inc.").
- Documento com menos de 200 caracteres de texto devolve erro 422 (provavelmente PDF escaneado, sem OCR).

2. Regras de detecção

Regra	Severidade	Referência
Senha "segura" ou "forte" sem tamanho, complexidade ou bloqueio	alta	NIST IA-5; MITRE T1110
Acesso remoto ou VPN sem autenticação multifator	alta	NIST IA-2(1); MITRE T1133
Incidente sem prazo, responsável ou comunicação à ANPD e aos titulares	alta (duas ou mais faltas) ou média	LGPD Art. 48; NIST IR-6
Declaração genérica de conformidade com a legislação	média	LGPD Art. 46
Dispositivo pessoal sem controles mínimos	média	NIST AC-19
Ausência de encarregado de dados (DPO) no documento	média	LGPD Art. 41
Termos vagos: "sempre que possível", "periodicamente", "quando necessário", "em tempo hábil", "adequado"	média ou baixa	Conforme o tema (por exemplo, backup: NIST CP-9)

Glossários, definições e listas de referências não são analisados como regras da política.

3. Nota documental e Saúde de Compliance

Cada lacuna pesa 3 (alta), 2 (média) ou 1 (baixa). A nota cai conforme o peso total em relação ao tamanho do documento:

nota = 5 × (1 − peso total / (3 × unidades))

As unidades são o maior valor entre o número de seções, 5 e uma unidade a cada 10 frases, para que documentos longos não sejam punidos só pelo tamanho. A nota fica entre 0 e 5, com uma casa decimal.

A Saúde de Compliance é igual à nota documental enquanto não houver Verificação Prática; depois, a média das duas. Faixas: 4 ou mais, boa conformidade; 3 ou mais, parcial; 2 ou mais, baixa; abaixo de 2, crítica. A fórmula é uma heurística provisória, calibrada nas políticas de teste.

4. Busca semântica de normas

O índice FAISS tem 1.705 vetores (768 dimensões) de 1.087 normas: NIST SP 800-53 (1.014 controles) e LGPD (73 artigos). Normas longas são divididas em trechos de cerca de 150 tokens. Para cada lacuna, a consulta é o trecho mais o problema; entre os 6 resultados mais próximos, valem os que passam em um limiar de similaridade por tipo (controle NIST da mesma família da regra: 0,45; outra família: 0,62; LGPD: 0,66), no máximo 2. Essas normas são acrescentadas à referência como "Normas próximas (busca semântica)" e guardadas em `normas_ref`.

Banco de dados MongoDB

O MongoDB 7 guarda três coleções, acessadas só por `db/repositorio.py`.

Coleção	Conteúdo
`normas`	1.087 normas (NIST SP 800-53 e LGPD) com identificador, título, texto e mapeamentos
`auditorias`	Arquivo, hash SHA-256, status, indicação de Verificação Prática e datas
`relatorios`	Notas, `lacunas[]` e `verificacoes[]` embutidas, ligadas à auditoria; cada lacuna aponta as normas em `normas_ref`

A integridade é garantida em três camadas, porque a instância é standalone e não há transações: validador `$jsonSchema`, índices únicos (norma por fonte e identificador; um relatório por auditoria) e regras no repositório. Entre elas, a auditoria é criada antes do relatório, o relatório é apagado antes da auditoria e uma norma citada por uma lacuna não pode ser removida. O limite de documento do MongoDB é 16 MiB.

Como executar

Pré-requisitos: Docker com Compose v2 e conda (Miniforge ou Miniconda). Na raiz do repositório:

```
conda env create -f setup/environment.yml
conda activate autoaudit
cp .env.example .env          # ajuste as senhas; nunca versione o .env
docker compose up -d          # MongoDB e mongo-express
python db/init_db.py          # coleções, validador e índices
```

```
python scripts/download_nist_oscal.py
python scripts/download_lgpd.py
python db/seed_normas.py      # 1.087 normas
python db/seed_exemplo.py     # relatórios de exemplo
python db/build_faiss.py      # índice FAISS (data/processed/)

uvicorn backend.main:app      # API em http://localhost:8000 (docs em /docs)
streamlit run frontend/app.py # frontend em http://localhost:8501
```

Para testar um documento sem subir a API nem o banco:

```
python backend/analisar_arquivo.py caminho/politica.pdf
```

Testes e validação: `python backend/validar_gabarito.py` (gabarito da Nimbus), `python backend/testar_busca.py` (busca semântica) e, com a API no ar, `python backend/testar_api.py` (ponta a ponta).

Resultados e validação

O motor achou as 6 lacunas plantadas no gabarito da política fictícia Nimbus, sem falsos positivos, e a versão revisada dessa política (escrita seguindo as sugestões do relatório) recebeu nota 5,0 sem nenhuma lacuna.

Documento	Tipo	Nota documental	Lacunas
Nimbus Logística (PDF e DOCX)	Fictício, com falhas propositais	2,5	6
Nimbus Logística revisada (DOCX)	Fictício, corrigido	5,0	0
Alfa Saúde	Fictício	1,9	7
Orion Pagamentos	Fictício	2,1	6
Modelo de política de segurança (Governo Digital)	Real, público, 24 páginas	4,0	9
PoSIC da UFPE	Real, público, 20 páginas	3,9	9
PoSIC do IFB	Real, público, 23 páginas	3,7	11

Os documentos reais são políticas públicas de órgãos governamentais, em estilo normativo; testes com eles levaram à correção de falsos positivos (definições, listas de normas e fragmentos de lista). A nota para esse tipo de documento é indicativa.

O fluxo completo foi verificado com a API, o MongoDB, o índice FAISS e o frontend rodando: o relatório gravado aparece no mongo-express e no histórico do app.

Limitações e próximos passos

Limitações desta versão

- A Verificação Prática não foi executada: a nota considera só a análise documental.
- As regras cobrem um conjunto limitado de problemas, em português, e não usam LLM; nota alta significa que as regras atuais não acharam nada, não conformidade total.
- Há uma única regra de ausência (encarregado de dados), e a regra de senha aceita qualquer valor numérico citado, mesmo fraco.
- PDF escaneado não é suportado, porque não há OCR.
- Títulos sem numeração só são reconhecidos em maiúsculas ou no estilo Título do Word; PDFs com numeração inconsistente geram seções imprecisas.
- A fórmula da nota é uma heurística provisória.
- A demonstração é local: o Streamlit Cloud não alcança a API nem o MongoDB do notebook.

Próximos passos

1. Mais regras de detecção e calibração da nota com documentos reais.
2. Carga do CIS Controls v8 e de templates SANS na base de normas.
3. LLM com recuperação (RAG) sobre o índice FAISS, para sugestões de redação mais ricas.
4. Apresentação final e artigo da disciplina.
5. Por último, e somente depois de todas as etapas anteriores estarem concluídas e validadas: a Verificação Prática, um pentest controlado em ambiente de laboratório (DVWA, Juice Shop, Metasploitable), preenchendo `nota_pratica` e `verificacoes`.